

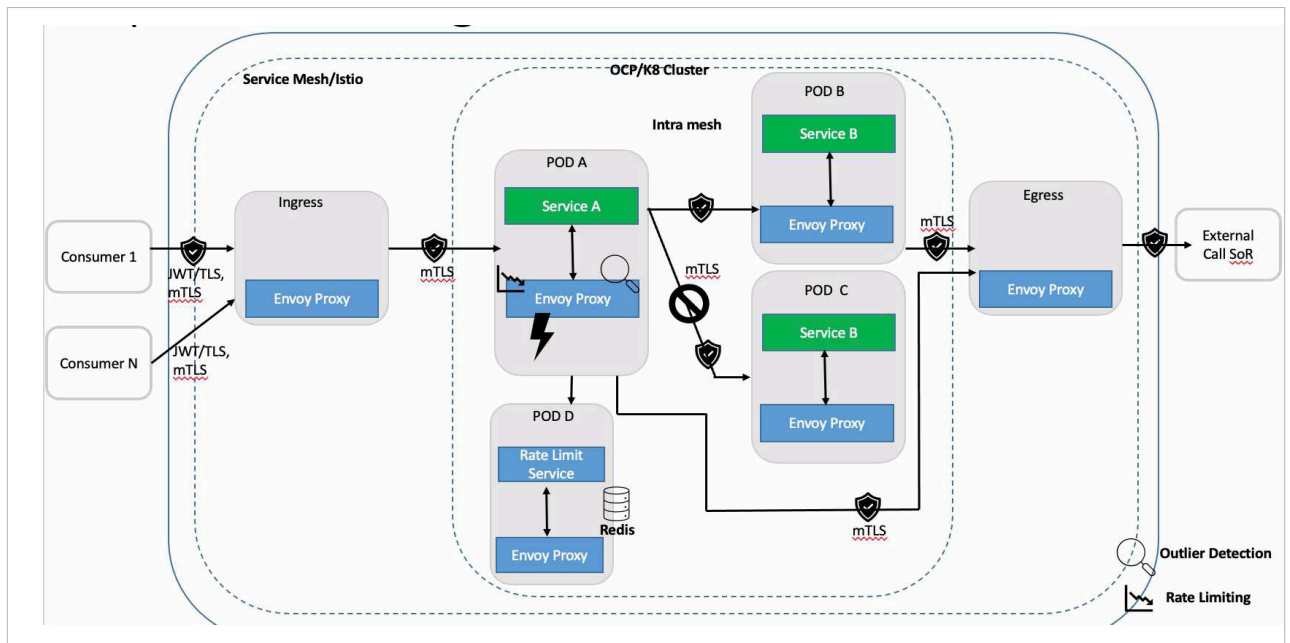


Figure 5: Request throttling

the authorised server or in the enterprise identity provider (IDP) system. It will also validate the claims in JWT and its correctness. And it will validate the scope in the access token against the authorisation policy for the target resource to decide whether access should be granted or not.

Security area: Managed ingress

Solution: All traffic to service must pass through the *ingress gateway*, ensuring that all pods require mTLS with certificates and identities provided by the service mesh control plane.

Application: This can be achieved by using the peer authentication policy applied in the name space of the pod, so that without mTLS pods do not accept requests in plain text traffic.

Security enforcement point: Securing intra mesh traffic

Security area: Application authentication

Solution: Pod to pod communication must be secured by mTLS configuration between sidecar proxies. A unique service account should be used for running each of the workloads in Kubernetes.

Application: Kubernetes service accounts are used to provide unique identities for each of the services of the cluster. The authentication policy discussed in the managed ingress section will ensure pods do not accept direct traffic from outside of the mesh.

Security area: Application authorisation

Solution: Use sidecar policy to control which pods can communicate with other pods. Authorisation policies should be used to explicitly define which workloads should be able to communicate with other workloads.

Override default behaviour to deny all traffic to communicate with each other.

Application: Side car policy for all pods in a name space and in the name space of ingress and egress should be configured to restrict communication between services.

Security area: Managed intra-mesh

Solution: Service mesh wide mTLS along with the above mentioned policy will ensure pods can communicate with other Istio enabled pods.

Application: Enforced through mesh wide policy of ‘STRICT’ mTLS if there is no requirement to integrate with other pods that are not managed by sidecar.

Security area: Segmentation

Solution: Related services should be deployed in the same name space.

Application: In OpenShift implementation this is taken care of by creating an individual project.

Security enforcement point: Securing egress traffic

Security area: Authentication

Solution: Services within the service mesh that communicate with an external system must communicate to egress using mTLS. mTLS from service mesh should terminate at egress, and an appropriate policy should verify this before any new connection is established for the external API call. Certificates required for any specific authentication with the external system will be configured within the service mesh and used by the gateway.

Application: This needs communication to be set up with the egress gateway, with specific custom resource definition (CRD).